

VULNERABILITY ASSESSMENT REPORT

Web Application Penetration Testing — Information Disclosure Finding

Sensitive Information Disclosure

phpinfo() Page Exposure

Vulnerability Class: Information Disclosure (CWE-200)

Affected File: info.php — publicly accessible diagnostic page

CVSS v3.1 Base Score: 5.3 (Medium) — escalates to High in attack chain

PHP Version Exposed: 7.4.33 — End-of-Life since 28 November 2022

SEVERITY RATING

MEDIUM

(HIGH in Attack Chain)

Report Reference: VAR-2025-PHP-009

Date of Assessment: 14 July 2025

Target Domain: results.kongu.edu

Classification: CONFIDENTIAL — For Authorised Personnel Only

1. Executive Summary

The web server associated with the domain results.kongu.edu is configured to expose a publicly accessible phpinfo() diagnostic page at the path /info.php. This page, intended solely for development and debugging purposes, outputs a comprehensive dump of the PHP runtime environment and server configuration without requiring any form of authentication.

The information disclosed includes the PHP version, operating system and kernel build, internal filesystem paths, enabled extensions, and server API type. Individually, these data points may appear low-risk; however, in the context of a targeted attack chain, this disclosure provides an adversary with a precise blueprint of the server’s architecture, substantially reducing the effort required to identify and exploit applicable vulnerabilities.

 **Severity Note**

This vulnerability is rated Medium in isolation (CVSS 5.3). However, in the context of a multi-stage attack chain — particularly given that PHP 7.4.33 is End-of-Life and the FPM/FastCGI server API is exposed — the effective severity escalates to High. The combination of an outdated runtime and full configuration disclosure creates conditions suitable for known remote code execution exploits.

Vulnerability Summary

Vulnerability Name	Sensitive Information Disclosure via phpinfo() Exposure
Severity	Medium (High in attack chain)
CVSS v3.1 Score	5.3 — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
CWE Classification	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor
Vulnerability Class	Information Disclosure / Improper Server Configuration
Target URL	http://results.kongu.edu/info.php
Authentication Required	None — Fully unauthenticated access
PHP Version Disclosed	7.4.33 — End-of-Life (EOL since 28 November 2022)
Report Reference	VAR-2025-PHP-009
Date Identified	14 July 2025
Status	Open — Awaiting Remediation

2. Technical Details

This section documents the specific technical data exposed by the phpinfo() page and the methodology used to identify and verify the vulnerability.

2.1 Identification Methodology

The vulnerable page was identified through standard web application reconnaissance. Directory and file enumeration against the target domain revealed the presence of `info.php` at the web root. Navigating to this path via a standard HTTP GET request returned the full PHP configuration page with HTTP 200 OK, confirming unauthenticated access.

```
# HTTP Request / Response
GET /info.php HTTP/1.1
Host: results.kongu.edu

HTTP/1.1 200 OK
Content-Type: text/html; charset=UTF-8

# Response body: Full phpinfo() HTML output rendered in browser
```

2.2 Exposed Server Environment Data

The following sensitive environmental details were directly observed from the `phpinfo()` output:

PHP Version	7.4.33 — End-of-Life, no security patches issued post-November 2022
Operating System	Red Hat Enterprise Linux 9.5 (Plow)
Kernel Version	5.14.0-575.el9.x86_64
Build Provider	Remi's RPM Repository
Server API	FPM/FastCGI
Configuration Path	/etc/opt/remi/php74/
PHP INI Location	/etc/opt/remi/php74/php.ini (internal path disclosed)
Notable Extensions	mysqlnd, curl, openssl, json, mbstring, PDO

2.3 Security Significance of Disclosed Data

PHP 7.4.33 (End-of-Life): This version has not received official security patches since November 2022. Multiple CVEs remain unpatched in production environments running this release, including CVE-2022-31630 and CVE-2022-31629.

Server API — FPM/FastCGI: The disclosure of the FastCGI Process Manager (FPM) as the server API is particularly significant. CVE-2019-11043, a critical remote code execution vulnerability in PHP-FPM, specifically targets this configuration when combined with an nginx server setup.

Internal File System Paths: The path `/etc/opt/remi/php74/` reveals the non-standard Remi repository installation structure. This information assists an attacker in crafting payloads and LFI (Local File Inclusion) exploit strings with accurate path references.

Enabled PHP Extensions: Knowledge of loaded extensions such as `mysqlnd`, `curl`, and `openssl` informs an attacker of available functions for post-exploitation. For example, `curl` functions may be abused for Server-Side Request Forgery (SSRF), while `openssl` confirms cryptographic capabilities useful for maintaining persistence.

3. Proof of Concept (PoC)

Exploitation of this vulnerability requires no specialised tooling. Any standard web browser or HTTP client is sufficient to reproduce the finding.

```
# Reproduction Steps

# Step 1: Navigate to the following URL in any web browser or HTTP client
http://results.kongu.edu/info.php

# Step 2: Observe the full PHP configuration page rendered without
authentication
# Expected output: Complete phpinfo() HTML page revealing:
#   - PHP Version, Build Date, System, Server API
#   - Configuration file paths and loaded .ini files
#   - All enabled extensions and their settings
#   - Environment variables and HTTP request headers
#   - $_SERVER superglobal contents
```

i Observation

The page was accessible over HTTP (unencrypted), which means any data observed by the researcher was also visible to any passive network observer on the same path. The use of plaintext HTTP further compounds the risk of this finding.

4. Impact Analysis

The impact of this vulnerability is evaluated across three scenarios: standalone exploitation, use as a reconnaissance enabler, and integration into a multi-stage attack chain.

4.1 Targeted Exploitation via Known CVEs

PHP 7.4.33 is an End-of-Life release. The following CVEs are directly applicable to the disclosed version and configuration, and can now be actively investigated by an attacker with knowledge of the exact version:

CVE-2022-31630

Out-of-bounds read in the `imageloadfont()` function. Applicable to installations with the GD extension loaded.

CVE-2022-31629	Session cookie security bypass allowing session hijacking under specific configurations.
CVE-2019-11043	Critical RCE in PHP-FPM when used with nginx and a misconfigured FastCGI configuration. Server API confirms FPM.

4.2 Environment Mapping and Privilege Escalation

The disclosed kernel version (5.14.0-575.el9.x86_64) on RHEL 9.5 allows an attacker, upon gaining initial access through any means, to immediately research applicable local privilege escalation (LPE) techniques specific to this kernel build without conducting noisy local enumeration that might trigger detection.

4.3 Configuration Abuse via Extension Knowledge

With knowledge of the specific extensions loaded on the server, an attacker can selectively craft payloads that leverage available PHP functions. The presence of mysqlnd indicates a MySQL/MariaDB backend is in use; curl enables SSRF vectors; and openssl confirms the availability of cryptographic functions used in advanced persistent implants.

● Combined Risk Assessment

The aggregate risk of this finding, when considering the EOL PHP version, exposed FPM/FastCGI API, and full path disclosure, is assessed as HIGH. An attacker who begins with this information has significantly reduced the time and noise required to achieve Remote Code Execution on this host.

5. Remediation Recommendations

The following remediation actions are listed in order of implementation priority. The first two items should be treated as immediate actions and completed within 24 to 48 hours of this report being received.

5.1 Immediate: Remove the info.php File [Priority: Critical]

The info.php file must be deleted from the production web server immediately. There is no legitimate reason for a phpinfo() diagnostic page to exist in a production environment. The file should be removed and its absence verified.

```
# Remediation Command
# Remove the file from the web root
rm -f /var/www/html/info.php

# Verify the file has been removed
ls -la /var/www/html/info.php
# Expected: No such file or directory

# Confirm the URL now returns 404
```

```
curl -I http://results.kongu.edu/info.php
# Expected: HTTP/1.1 404 Not Found
```

5.2 Immediate: Disable phpinfo() via php.ini [Priority: Critical]

As a defence-in-depth measure, the `phpinfo()` function should be disabled at the PHP configuration level. Even if another file containing a `phpinfo()` call is later introduced inadvertently, the function will be inoperative. Edit the `php.ini` file located at `/etc/opt/remi/php74/php.ini`:

```
# php.ini configuration
; Add phpinfo to the disable_functions directive in php.ini
; File: /etc/opt/remi/php74/php.ini

disable_functions = phpinfo, exec, passthru, shell_exec, system, proc_open,
popen

# Restart PHP-FPM to apply the change
systemctl restart php74-php-fpm
```

5.3 Short-Term: Upgrade PHP to a Supported Version [Priority: High]

PHP 7.4 reached official End-of-Life on 28 November 2022. No security patches have been issued for this branch since that date. The server should be upgraded to a currently supported PHP release at the earliest opportunity. As of the date of this report, the following versions are actively maintained:

- PHP 8.2 — Active support until 31 December 2024; Security support until 31 December 2026
- PHP 8.3 — Active support until 31 December 2025; Security support until 31 December 2027 [Recommended]
- PHP 8.4 — Latest stable release as of late 2024; Active support until 31 December 2026

5.4 Short-Term: Restrict Diagnostic Pages Behind Authentication [Priority: Medium]

If any diagnostic or informational pages are required for legitimate operational purposes, access must be restricted using one or more of the following controls:

- IP Whitelisting: Restrict access to the `/info.php` path to specific trusted administrative IP addresses using `.htaccess` or `nginx` location blocks.
- HTTP Basic Authentication: Protect diagnostic pages behind server-level HTTP authentication as a minimum baseline.
- Remove from Web Root: Store diagnostic scripts outside the publicly accessible web root and execute them locally only.

5.5 Ongoing: Enforce a Production Hardening Checklist

The presence of this file on a production server indicates a gap in the deployment or code review process. The following practices should be adopted to prevent recurrence:

- Include a pre-deployment checklist that explicitly checks for and rejects debug files (phpinfo.php, info.php, test.php, phptest.php) in the web root.
- Automate scanning of the web root for known sensitive filenames as part of the CI/CD pipeline.
- Implement a Web Application Firewall (WAF) rule to block responses containing the PHP Version string typically found in phpinfo() output.

6. References

- PHP Supported Versions — <https://www.php.net/supported-versions.php>
- CVE-2019-11043: PHP-FPM Remote Code Execution — <https://nvd.nist.gov/vuln/detail/CVE-2019-11043>
- CVE-2022-31630: PHP Out-of-Bounds Read — <https://nvd.nist.gov/vuln/detail/CVE-2022-31630>
- CVE-2022-31629: PHP Session Cookie Bypass — <https://nvd.nist.gov/vuln/detail/CVE-2022-31629>
- CWE-200: Exposure of Sensitive Information to an Unauthorized Actor — <https://cwe.mitre.org/data/definitions/200.html>
- OWASP Testing Guide — OTG-CONFIG-002: Test Application Platform Configuration
- OWASP Top 10 2021 — A05: Security Misconfiguration

End of Report

VAR-2025-PHP-009 — Sensitive Information Disclosure / phpinfo() Exposure
CONFIDENTIAL — For Authorised Personnel Only